

De los hallazgos a una revisión con evidencia.

Propuesta para evaluar un asistente de análisis de severidad cibernética en una organización.

Bryan Madrid

Ingeniería Civil Informática | Universidad Andrés Bello

Oportunidad

Unificar la captura de hallazgos, presentar una estimación de severidad y documentar la revisión del analista con probabilidades y explicaciones locales.

Qué se entrega

Capacidad	Entregable
Análisis individual	Estimación, distribución y reporte PDF.
Análisis por lotes	Plantilla CSV, validación de filas y resultados exportables.
Explicación y evidencia	LIME, métricas, comparación de modelos y casos reales del test.
Reproducibilidad	Modelo evaluado, dataset auditado, notebook y código fuente.

Estado actual: prototipo para un piloto supervisado. El beneficio operativo se medirá durante el piloto.

Un piloto de cuatro semanas

Duración propuesta, ajustable al alcance y disponibilidad de datos.

Etapa			Trabajo			Resultado		
Semana 1			Acordar casos de uso, activos, responsables y rúbrica de severidad.			Alcance y criterios de evaluación.		
Semana 2			Preparar una muestra local autorizada, revisar calidad y equivalencia de etiquetas.			Dataset revisado por especialistas.		
Semana 3			Evaluar el modelo y el flujo de revisión con un conjunto separado.			Métricas por clase y análisis de errores.		
Semana 4			Comparar decisiones y tiempos con la práctica actual.			Informe y decisión sobre continuidad.		

Indicadores que se deben medir

F1-Macro y recall por clase; subestimaciones graves; categorías desconocidas; proporción de resultados útiles para el analista; tiempo de revisión antes y después; concordancia con la rúbrica local.

Criterios para continuar

Acordar umbrales con el responsable de seguridad antes de medir. Continuar si el modelo cumple los criterios por clase y el flujo aporta valor; revisar o detener si las etiquetas no son equivalentes o la tasa de subestimación es inaceptable.

Requisitos del piloto

Responsable de seguridad, acceso autorizado a una muestra de hallazgos, rúbrica documentada, inventario de activos y un entorno de ejecución restringido. Las integraciones con SOC, SIEM y gestión de tickets se evaluarían como una fase posterior.

Evidencia y alcance

Resultados del escenario contextual de la tesis.

Elemento	Resultado
Modelo	Logistic_Regression ROS=False v=1
Variables	Fabricante, plataforma, producto y macrofamilia.
Selección	F1-Macro de seis clases en cuatro ventanas temporales de desarrollo.
Desarrollo / test	1520 / 397 registros, con purga por entidad.
Accuracy en test	66.75%
F1-Macro en test	0.5288
Dataset reconstruido	1984 registros; seis macrofamilias más casos pendientes.

Límites que debe resolver la validación local

- La etiqueta no equivale automáticamente a CVSS ni al riesgo del negocio.
- La clase low/medium no tiene soporte en el test temporal.
- Las variables de contexto pueden reflejar la procedencia de los registros.
- Las fechas disponibles no se verificaron como fechas de incidentes.
- La taxonomía y la equivalencia de etiquetas requieren revisión de un especialista.

Operación y datos

La aplicación procesa los archivos en memoria durante la sesión y no incorpora una base de datos de usuarios. Para uso compartido se debe desplegar detrás de los controles de acceso de la organización. No ejecuta contención ni remediación automática.

Próximo paso

Definir con la organización un caso de uso, la muestra autorizada y los indicadores del piloto. La propuesta no presupone eficacia operativa ni compromete niveles de servicio.